

5-ый этап индивидуального проекта

Основы информационной безопасности

Верниковская Е. А., НПИбд-01-23

17 мая 2025

Российский университет дружбы народов, Москва, Россия

Вводная часть

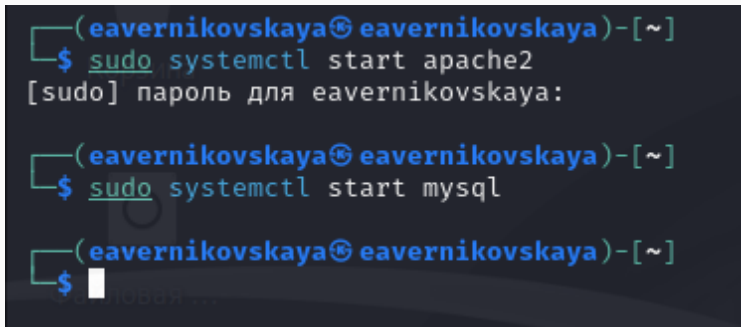
Научиться пользоваться Burp Suite.

1. Научиться пользоваться Burp Suite. Burp Suite представляет собой набор мощных инструментов безопасности веб-приложений, которые демонстрируют реальные возможности злоумышленника, проникающего в веб-приложения

Выполнение 5-ого этапа индивидуального проекта

Выполнение основных действий

Запустим mysql и apache2: *sudo systemctl start mysql* и *sudo systemctl start apache2* (рис. 1)



```
(eavernikovskaya@eavernikovskaya)~  
$ sudo systemctl start apache2  
[sudo] пароль для eavernikovskaya:  
  
(eavernikovskaya@eavernikovskaya)~  
$ sudo systemctl start mysql  
  
(eavernikovskaya@eavernikovskaya)~  
$
```

Рис. 1: Запуск mysql и apache2

Выполнение основных действий

Далее запустим Burp Suite (рис. 2)

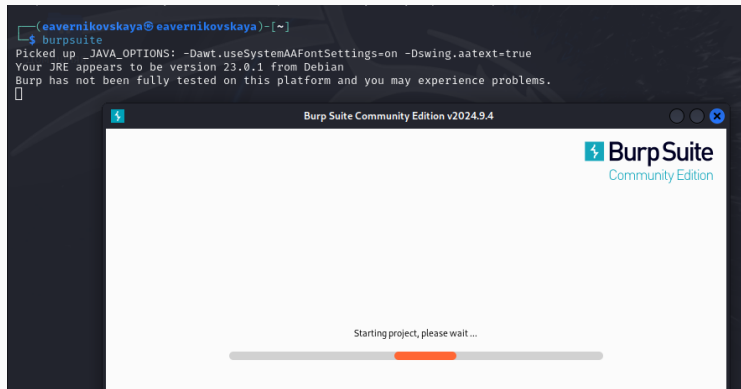


Рис. 2: Запуск Burp Suite

Откроем сетевые настройки браузера (рис. 3)

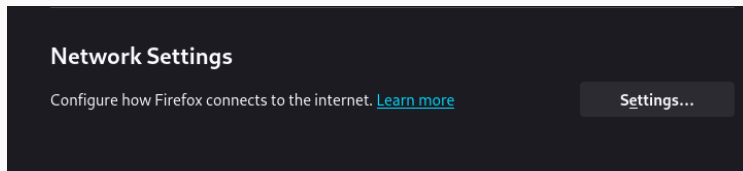


Рис. 3: Сетевые настройки браузера

Выполнение основных действий

Далее изменим настройки сервера для работы с проху и захватом данных с помощью Burp Suite (рис. 4)

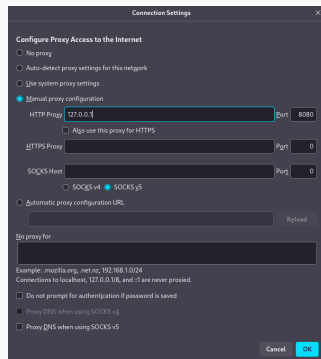


Рис. 4: Настройки сервера



Выполнение основных действий

Во вкладке Proxy установим “Intercept is on” (рис. 6)

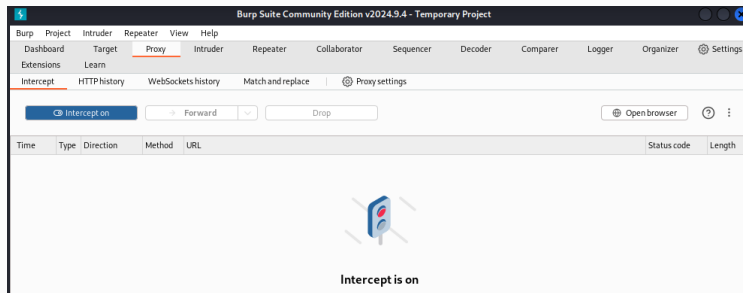


Рис. 6: Настройки Proxy

Выполнение основных действий

Для того чтобы Burp Suite работал исправно с локальным сервером установим параметр `network.allow_hijacking_localhost` на `true` (рис. 7)

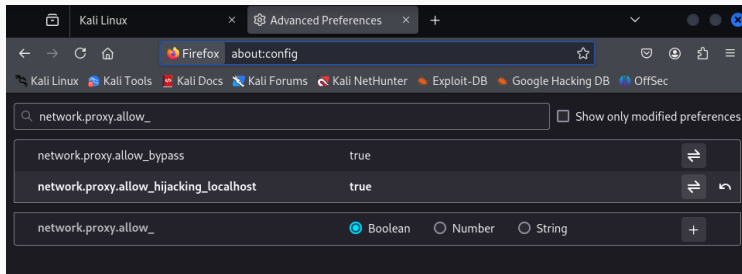


Рис. 7: Настройки параметров

Выполнение основных действий

Далее попытаемся зайти в браузере на сайт DVWA. Во вкладке Proxu появится захваченный запрос. Нажмём Forward чтобы загрузить страницу (рис. 8)

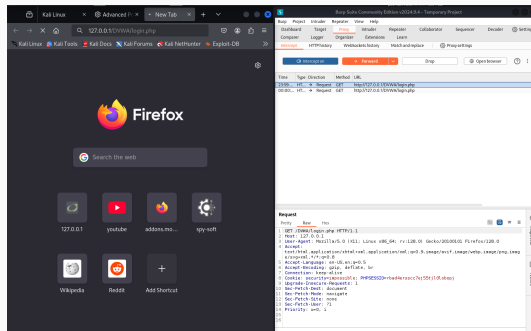


Рис. 8: Получаемые запросы сервера

Выполнение основных действий

После этого загрузится страница авторизации. Текст запроса поменяется (рис. 9)

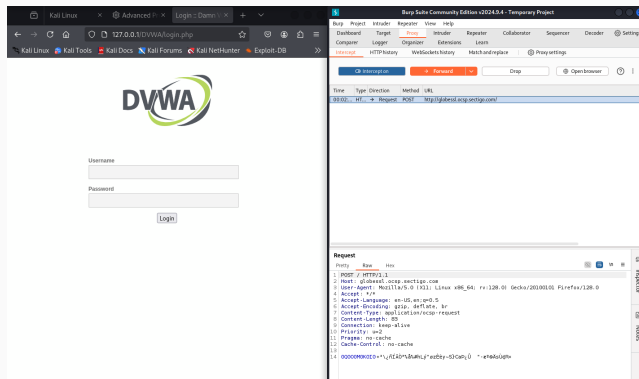


Рис. 9: Страница авторизации

История запросов хранится во вкладке Target (рис. 10)

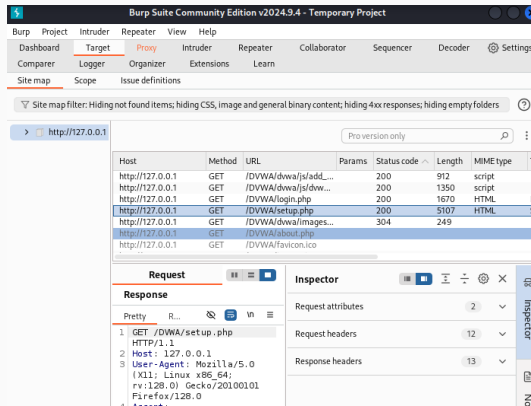


Рис. 10: История запросов

Выполнение основных действий

Введём неправильные данные в веб-приложение и нажмём на Login. В запросе мы увидим строку, в которой отображаются введённые нами данные (в поле для ввода) (рис. 11)

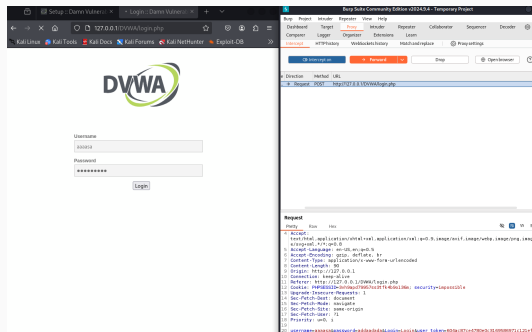


Рис. 11: Ввод случайных данных

Выполнение основных действий

Этот запрос можно найти во вкладке Target. Нажмём правой кнопкой мыши на хост нужного запроса и нажмём Send to Intruder (рис. 12)

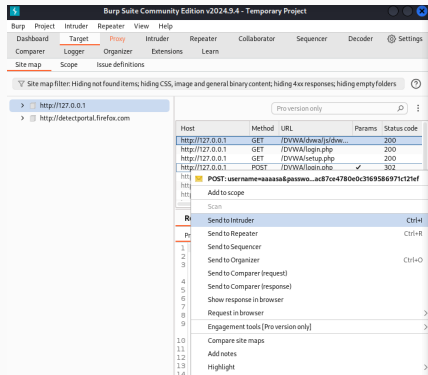


Рис. 12: POST-запрос с вводом пароля и логина

Выполнение основных действий

Далее переходим на вкладку Intruder. Мы увидим значения по умолчанию у типа атаки и наш введённый запрос (рис. 13)

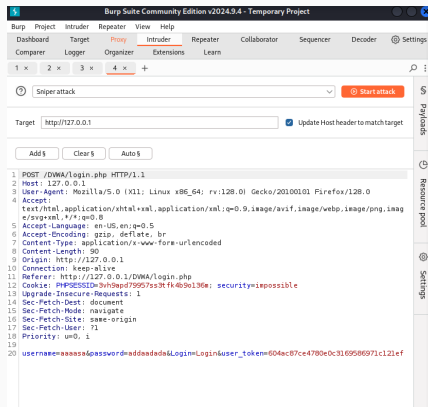


Рис. 13: Вкладка Intruder

Выполнение основных действий

Изменим значение типа атаки на Cluster bomb attack и проставим специальные символы у техданных, которые мы будем пробивать (то есть у имени пользователя и пароля) (рис. 14)

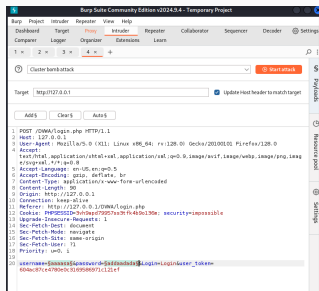


Рис. 14: Изменение типа атаки + специальные символы

Выполнение основных действий

Так как было отмечено 2 параметра для подбора, то нам нужно 2 списка со значениями для подбора. Далее заполняем 2 списка в Payload settings. В строке request count мы будем видеть нужное количество запросов, чтобы проверить все возможные пары пользователь-пароль (рис. 15), (рис. 16)

Payloads

Payload position: 1

Payload type: Simple list

Payload count: 6

Request count: 0

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

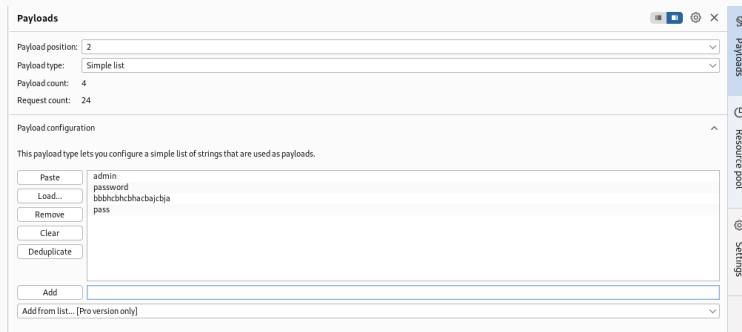
Paste admin
Load... password
Remove passwd
Clear 123456
Deduplicate dddddd
fffff

Add Enter a new item

Add from list... [Pro version only]

Рис. 15: 1ый Simple list

Выполнение основных действий



Payloads

Payload position: 2

Payload type: Simple list

Payload count: 4

Request count: 24

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste	admin
Load...	password
Remove	bbbbhchcbhacbjcbja
Clear	pass
Deduplicate	

Add

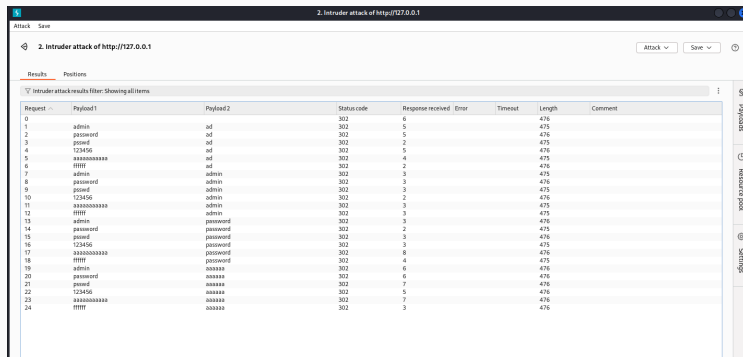
Add from list... [Pro version only]

Side panel: Payloads, Resource pool, Settings

Рис. 16: 2ой Simple list

Выполнение основных действий

Далее запустим атаку (рис. 17)



The screenshot shows the Burp Suite interface with the title "2. Intruder attack of http://127.0.0.1". The "Results" tab is active, displaying a table of attack results. The table has columns: Request, Payload 1, Payload 2, Status code, Response received, Error, Timeout, Length, and Comment. The table contains 25 rows of data, showing various payloads and their corresponding status codes and lengths.

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			302	6			476	
1	admin	ad	302	5			475	
2	password	ad	302	5			476	
3	passwd	ad	302	2			475	
4	123456	ad	302	5			476	
5	aaaaaaaaaa	ad	302	4			475	
6	fffff	ad	302	2			476	
7	admin	admin	302	3			475	
8	password	admin	302	3			476	
9	passwd	admin	302	3			475	
10	123456	admin	302	2			476	
11	aaaaaaaaaa	admin	302	3			475	
12	fffff	admin	302	3			475	
13	admin	password	302	3			476	
14	password	password	302	2			475	
15	passwd	password	302	3			476	
16	123456	password	302	3			475	
17	aaaaaaaaaa	password	302	8			476	
18	fffff	password	302	4			475	
19	admin	aaaaaa	302	6			476	
20	password	aaaaaa	302	6			476	
21	passwd	aaaaaa	302	7			476	
22	123456	aaaaaa	302	5			476	
23	aaaaaaaaaa	aaaaaa	302	7			476	
24	fffff	aaaaaa	302	3			476	

Рис. 17: Запуск атаки

Выполнение основных действий

При открытии каждого post-запроса можно увидеть полученный get-запрос. В нём видно куда нас перенаправляют после выполнения ввода пары пользователь пароль. На (рис. 18) с подбором пары admin-ad видно, что нас перенаправляют на страницу login.php. Это значит что пара не подходит

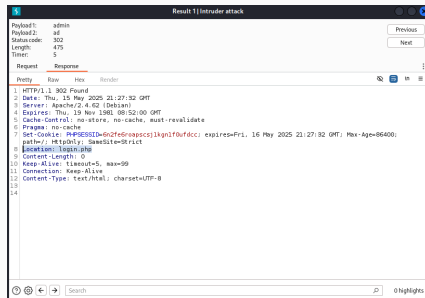


Рис. 18: Результат запроса (1)

Выполнение основных действий

Далее проверим результат пары sdmin-password. В этом случае нас перенаправляют на страницу index.php. Это значит что пара верная (рис. 19)

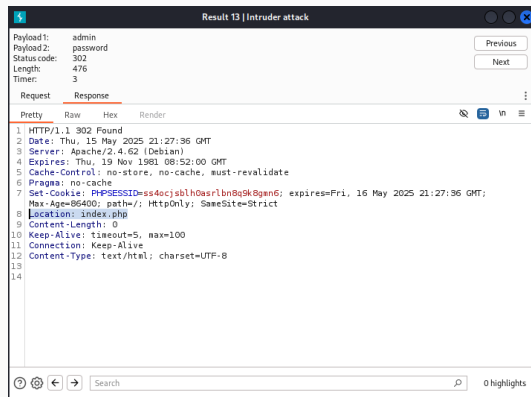


Рис. 19: Результат запроса (2)

Выполнение основных действий

Также есть дополнительная проверка. Для этого нужно нажать на Send to Repeater (рис. 20)

10	123456	admin
11	aaaaaaaaaa	admin
12	ffffff	admin
13	admin	
14	password	
15	psswd	
16	123456	
17	aaaaaaaaaa	
18	ffffff	
19	admin	
20	password	
21	psswd	
22	123456	
23	aaaaaaaaaa	
24	ffffff	

Result #13

Scan

Send to Intruder Ctrl+I

Send to Repeater Ctrl+R

Send to Sequencer

Send to Organizer Ctrl+O

Send to Comparer (request)

Send to Comparer (response)

Рис. 20: Дополнительная проверка результата

Переходим во вкладку Repeater (рис. 21)

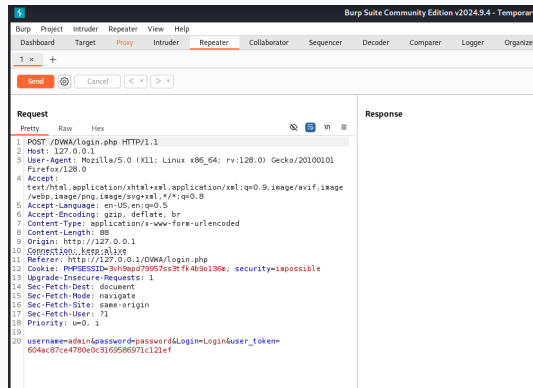


Рис. 21: Вкладка Repeater

Нажмём на send. И получим в Response перенаправление на index.php (рис. 22)

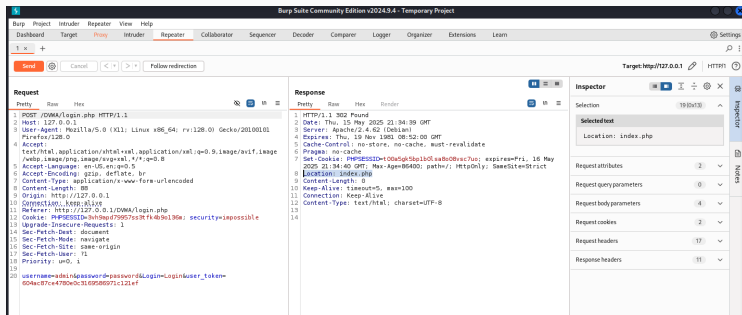


Рис. 22: Окно Response

Выполнение основных действий

Далее нажмём Follow redirection. После этого мы получим html код в окне Response (подокно Pretty) (рис. 23)

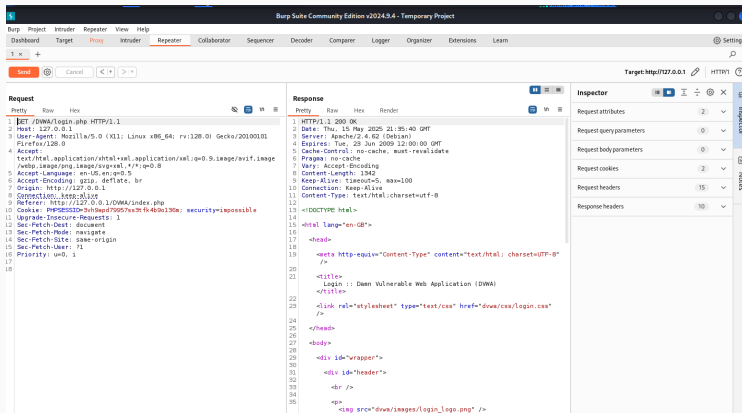


Рис. 23: html в окне Response

Выполнение основных действий

Далее в подокне Render получим то как выглядит полученная страница (рис. 24)

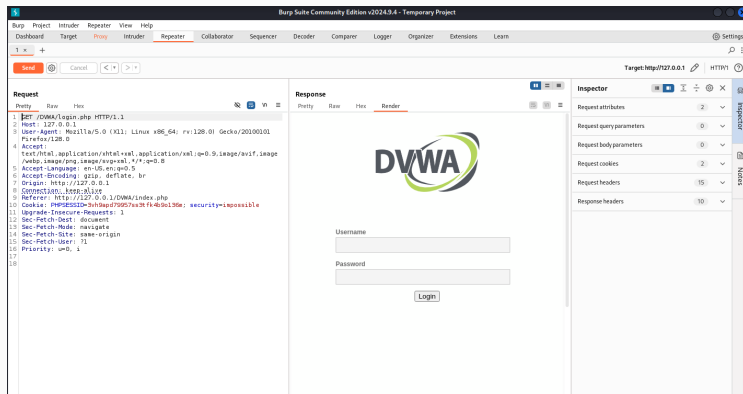


Рис. 24: Полученная страница

Подведение итогов

В ходе выполнения 5-ого этапа индивидуального проекта мы научились использовать инструмент Burp Suite

1. Этапы реализации проекта [Электронный ресурс] URL:
<https://esystem.rudn.ru/mod/page/view.php?id=1220336>